SAML 2.0 單一登入

接收系統是 SP；中央 SSO 是 IdP

1. **瀏覽器 → SP 登入啟動頁**
   SP 保存 Request ID 與本次瀏覽器關聯。
2. **SP → 瀏覽器 → IdP /saml/sso**
   HTTP-Redirect；以 SP 私鑰簽署 SAMLRequest 查詢字串。
3. **IdP 驗請求及中央登入**
   核對 SP、簽章、ACS、Destination、時間與重放。
4. **IdP → 瀏覽器 → SP 的 ACS**
   HTTP-POST：SAMLResponse 與 RelayState。
5. **SP 套件驗證回應**
   信任 IdP 憑證；驗簽章、Issuer、Audience、Recipient、期限與 InResponseTo。
6. **SP 建立本地登入**
   使用 IdP Entity ID + NameID 對應帳號，依本地權限進入服務。

交換資料	內容
IdP metadata / Entity ID	https://sso.example.edu/saml/metadata
IdP SSO URL	https://sso.example.edu/saml/sso
SP 提供	SP Entity ID、精確 HTTPS ACS、登入啟動網址
SP 公開憑證	有效的 PEM RSA 簽章憑證，至少 2048 位元；私鑰留在 SP
IdP 公開憑證	由可信 metadata 匯入；中央管理者另核對來源及憑證輪替

中央目前不自動下載 SP metadata 建立信任；由管理者登記。請確認 SP 模組能採用本版的 Binding 與簽章要求。

> 本文件為目前開發版介面規格；正式網址、系統代碼、密鑰 / 憑證、授權欄位與測試帳號請向 SSO 管理者取得。example.edu 為示意位址，不可直接呼叫。

SAML 2.0 單一登入

接收系統是 SP；中央 SSO 是 IdP

請求與回應格式

方向	欄位與規則
Redirect 查詢	SAMLRequest、RelayState（選用）、SigAlg、Signature；RSA-SHA256 簽署查詢字串，交由 SAML 套件處理壓縮、編碼與簽章。
AuthnRequest	唯一 ID、IssueInstant、Version=2.0、Issuer=SP Entity ID、Destination=IdP SSO URL；ACS 指定時須完全相符。
RelayState	UTF-8 最多 80 bytes；使用短隨機關聯值，不塞個資或任意外部返回網址。
ACS POST	SAMLResponse（Base64 XML）、RelayState；驗證成功才能建立本地登入。
回應驗證	成功 Response 與 Assertion 都有簽章；檢查 InResponseTo 對應原始請求且僅接受一次。
固定識別	NameID 使用 persistent 格式，值為穩定帳號 ID。

允許提供的 Attribute

Attribute Name	說明
preferred_username	校園登入帳號；學生為學號、教職員為員編
name	姓名
identity_type	身分類型，例如 student / employee；依實際來源，不自行推測
class_code	班級代碼
class_name	班級名稱
student_status_code	學籍狀態代碼
student_status_name	學籍狀態名稱
education_level_code	學制代碼
education_level_name	學制名稱

SAML 的帳號欄位仍為 preferred_username；Web API JSON 才使用 username。屬性受系統欄位白名單限制；不使用 OIDC scope。

> 本版支援 SP 發起的基本登入；不提供完整 SLO、IdP 主動登入或加密 Assertion。ForceAuthn=true、索引型 ACS / AttributeConsumingServiceIndex 等不支援。未登入時 IsPassive 不能跳出互動登入。

SAML 2.0 單一登入

接收系統是 SP；中央 SSO 是 IdP

SP 套件設定示意

```
IdpMetadataUrl = "https://sso.example.edu/saml/metadata"
SpEntityId = "https://app.example.edu/saml"
AcsUrl = "https://app.example.edu/saml/acs"
RequestBinding = "HTTP-Redirect"
ResponseBinding = "HTTP-POST"
SignAuthnRequest = true
SignatureAlgorithm = "RSA-SHA256"
NameIdPolicy = "persistent"
SpPrivateKey = secretStore.Read("SP_SIGNING_PRIVATE_KEY")
```

設定名稱依 SP 套件而異，上例是概念設定。ACS 不是一般首頁，須由套件處理 SAMLResponse；禁止自行只讀 NameID 就視為通過驗證。

ACS 處理順序

- 核對瀏覽器關聯及 RelayState；驗證可信 IdP 的 Response / Assertion 簽章。
- 驗證 Issuer、Audience、Destination / Recipient、NotBefore / NotOnOrAfter 及 InResponseTo。
- 確認成功狀態並拒絕重放；對應本地帳號、檢查停用及業務權限。
- 建立自己的 Cookie，導向原先允許的站內頁面；不保存完整 Assertion 到一般日誌。

時間及測試

本版 AuthnRequest 允許過去 5 分鐘至未來 30 秒的 IssueInstant；Assertion 與 SubjectConfirmation 有效期設定 2 分鐘，接收端依回應驗證。兩端須同步時間。

- 正常登入、中央已登入與登入逾時三種情境都要測試。
- 錯誤回呼、錯誤密鑰 / 簽章、票券重放、停用系統與停用帳號必須拒絕。
- 只有允許的欄位才可使用；欄位缺少或空白要能處理。
- 本地帳號未開通或沒有業務權限時顯示拒絕頁，不自動授予管理權。
- 登入後導向不含 code / ticket 的站內頁面；日誌不留原始密鑰、票券或 Token。

> 中央與接收系統各自建立 Cookie / Session。中央登入有效可省略再次輸入帳密；接收系統仍須完成驗證。中央登出不等於所有下游同時登出，本版未實作完整跨系統單一登出。

規範參考：OASIS SAML 2.0 Profiles。實際相容能力需以 SP 套件及雙方互通測試確認。

實作核對：src/NkustSso.Server/Controllers/SamlSsoController.cs；Services/SamlIdentityProvider.cs；Services/IdentityClaimReleasePolicy.cs